

# Autenticação e Autorização

---

Segurança no API Gateway

AWS Certified Developer Associate

Instrutor: Marlon Anesi

# Métodos de Autenticação

## 1. IAM Authentication

- Usa credenciais AWS (Access Key + Secret Key)
- Autenticação baseada em assinatura SigV4
- Ideal para: serviços AWS, aplicações internas

## 2. Amazon Cognito User Pools

- Gerenciamento completo de usuários
- Signup, signin, recuperação de senha
- Retorna token JWT após autenticação
- Ideal para: apps móveis, web apps com usuários

## 3. Lambda Authorizer (Custom)

- Função Lambda customizada para validação
- Suporta OAuth, SAML ou qualquer lógica customizada
- Token-based ou Request-based
- Ideal para: autenticação complexa, third-party

# Lambda Authorizer em Detalhes

## Tipos de Lambda Authorizer

### 1. TOKEN-based:

- Recebe token no header (Authorization: Bearer token)
- Lambda valida token e retorna policy IAM
- Exemplo: JWT, OAuth tokens

### 2. REQUEST-based:

- Recebe toda requisição: headers, query, path, body
- Validação baseada em múltiplos parâmetros
- Exemplo: validar IP, User-Agent, custom headers

## Resposta do Lambda

Deve retornar:

- principalId: identificador do usuário
- policyDocument: IAM policy (Allow/Deny)
- context (opcional): dados passados ao backend

# Resource Policies e CORS

## Resource Policies

Políticas JSON aplicadas à API para controlar acesso:

- Permitir/negar contas AWS específicas
- Restringir por faixa de IPs (whitelist/blacklist)
- Permitir acesso apenas de VPCs específicas

## CORS (Cross-Origin Resource Sharing)

Permite que aplicações web em um domínio acessem API em outro:

- Configurar: origens permitidas, métodos, headers
- REST APIs: configuração manual
- HTTP APIs: CORS nativo simplificado

## Importante

Sempre habilite CORS para APIs acessadas de browsers!

# Comparação e Escolha

## IAM Auth

### Quando usar:

- APIs internas AWS
- Serviço-a-serviço
- Sem usuários externos

Prós: Simples, integrado  
Contras: Só AWS

## Cognito

### Quando usar:

- Apps móveis/web
- Gerenciar usuários
- Login social (Google, FB)

Prós: Completo, JWT  
Contras: Custo adicional

## Lambda Authorizer

### Quando usar:

- OAuth, SAML
- Lógica customizada
- Third-party auth

Prós: Flexível, qualquer lógica  
Contras: Mais complexo

## Boas Práticas

- Sempre use HTTPS (API Gateway força HTTPS por padrão)
- Combine com throttling para proteção adicional
- Use CloudWatch para monitorar tentativas de acesso não autorizadas
- Implemente retry com exponential backoff no cliente



# Pontos-chave para Revisão

## 1. Métodos de Autenticação

- IAM: serviços AWS, SigV4
- Cognito: apps móveis/web, JWT
- Lambda Authorizer: custom, OAuth, SAML

## 2. Lambda Authorizer

- TOKEN-based: valida token do header
- REQUEST-based: valida requisição completa
- Retorna: principalId + policyDocument + context

## 3. Outros Controles

- Resource Policies: whitelist IPs, VPCs, contas
- CORS: sempre habilite para apps web

***LEMBRE-SE: Se menciona 'usuários externos' > Cognito! Se menciona 'custom auth' > Lambda Authorizer! Se menciona 'serviços AWS' > IAM!***